

CIA ÜÇLÜSÜ

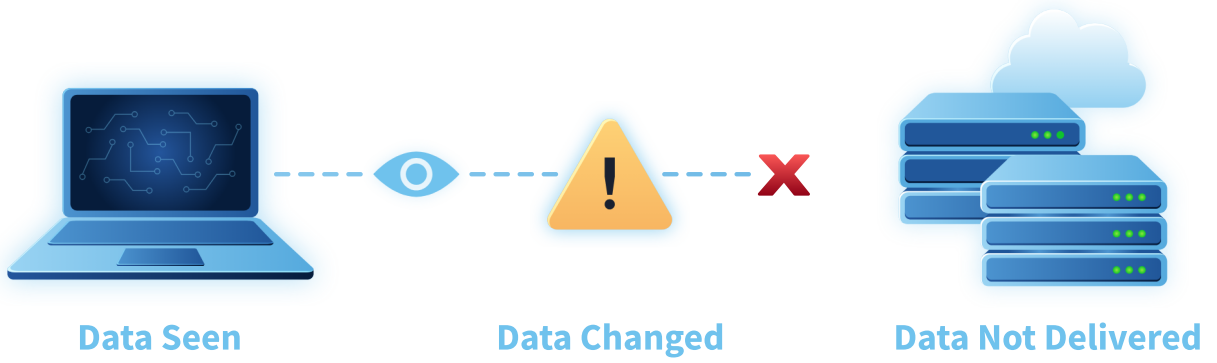
[Kaynak](#)

İÇERİK

1. CIA Üçlüsünü Anlamak

CIA Üçlüsünü Anlamak

Bilgi güvenliği, yalnızca güvenlik araçlarının (Firewall, EDR, IDS/IPS) sisteme entegre edilmesi veya saldırıların engellenmesinden ibaret değildir. Siber güvenlikte asıl amaç, dijital verinin spesifik yapısal koşullarını korumaktır. Geleneksel fiziksel medyalardan (kağıt) dijital sistemlere ve ağlara taşınan verinin güvenliği, savunma ve saldırı operasyonlarının (Blue Team & Red Team) etrafında şekillendiği üç temel ilkeye dayanır: **CIA Triad** (Confidentiality, Integrity, Availability).



Tüm siber güvenlik mimarisi, zafiyet analizleri ve tehdit modellemeleri bu üç sütunun bütünlüğünü sağlamak veya istismar etmek üzerine kuruludur.



Confidentiality (Gizlilik)

Confidentiality (Gizlilik: Hassas verilerin ve sistem kaynaklarının yalnızca önceden yetkilendirilmiş (authorized) kişi, süreç veya uygulamalar tarafından erişilebilir olmasını garanti eden prensip), veri güvenliğinin ilk katmanıdır.

Bu prensibin ihlali, yetkisiz kişilerin veriye erişmesiyle sonuçlanır ve doğrudan finansal kayıplara, mahremiyet ihlallerine veya hukuki yaptırımlara (KVKK/GDPR cezaları) yol açar.

Saldırı Vektörü (Senaryo): Herkese açık bir ağda (örneğin bir kafenin Wi-Fi ağı) sosyal medya hesabına giriş yaparken bağlantının arasına girilmesi (MITM - Man-in-The-Middle / Sniffing) ve kimlik bilgilerinin (credentials) ağ üzerinden düz metin (plaintext) olarak ele geçirilmesi, **Confidentiality** ilkesinin doğrudan yıkılmasıdır. Saldırgan, erişim hakkı olmayan bir veriyi okumuştur.

Savunma Mekanizmaları: Dijital dünyada bu ilkeyi korumak için iki temel yapı taşı kullanılır:

1. **Encryption** (Şifreleme: Verinin hem durağan haldeyken "Data at Rest" hem de ağ üzerinde aktarılırken "Data in Transit" kriptografik algoritmalarla okunamaz hale getirilmesi).
2. **Access Controls** (Erişim Kontrolleri: Sistemdeki kaynaklara kimin ulaşabileceğini belirleyen yetkilendirme mekanizmaları, örn: IAM politikaları).

ÖNEMLİ: Veri sızıntıları (Data Breaches), doğrudan bir Confidentiality zafiyetidir.

Durum / Senaryo	Confidentiality Sağlandı mı?	Teknik Analiz / Yorum
Gmail kimlik bilgilerinin ofis masasındaki yapışkan notlarda yazılı olması.	Hayır	Fiziksel güvenlik zafiyeti; kimlik bilgilerinin yetkisiz gözlemcilere açıkta bırakılması (Shoulder Surfing riski).
Şirket içi dahili belgelerin yalnızca iş için ihtiyaç duyan çalışanların erişimine açık olması.	Evet	"Least Privilege" (En Az Ayrıcalık) ilkesi uygulanmış, yetkili erişim denetimi (Access Control) başarılı.
Kişisel ve hassas bir belgenin internette açıkça erişilebilir olması.	Hayır	Yanlış yapılandırma (Misconfiguration) veya veri sızıntısı sonucu yetkisiz kamuya açık erişim.

Integrity (Bütünlük)

Integrity (Bütünlük: Verinin yalnızca yetkili kişiler tarafından ve onaylanmış yöntemlerle değiştirilebilmesi; verinin yaşam döngüsü boyunca doğruluğunun, tutarlılığının ve güvenilirliğinin korunması), veriye duyulan güvenin temelidir.

Bu ilke olmadan, verinin değiştirilip değiştirilmediği bilinemez ve sisteme/veriye olan güven tamamen kaybolur. Özellikle finansal, sağlık veya kritik altyapı sistemlerinde **Integrity** ihlalleri felaketle sonuçlanabilir.

Saldırı Vektörü (Senaryo): Bir mobil cihaz üzerinden banka transferi başlatıldığında, işlemin (transaction) tamamlanmadan önce ağ üzerinde yakalanması ve alıcı hesap bilgilerinin veya transfer miktarının yetkisiz bir şekilde değiştirilmesi (Parameter Tampering / Data Manipulation). İşlem gerçekleşir ancak veri tahrif edildiği için para yanlış hedefe gider. Ayrıca bir saldırganın sisteme sızdıktan sonra izlerini kaybettirmek için log dosyalarını silmesi veya değiştirmesi de kritik bir Integrity ihlalidir.

Savunma Mekanizmaları: Dijital dünyada bütünlüğü doğrulamak için **Hashing** (Özet algoritmaları; örn. SHA-256), **Digital Signatures** (Dijital İmzalar) ve **Checksum** (Sağlama Toplamı) doğrulamaları kullanılır.

Durum / Senaryo	Integrity Sağlandı mı?	Teknik Analiz / Yorum
Verinin, yetkilendirilmiş bir onay mekanizması üzerinden değiştirilmesi.	Evet	Veri modifikasyonu beklenen, yetkili ve izlenebilir bir süreç üzerinden (Audit Trail) gerçekleşmiş.
Öğrenci yoklama kayıtlarının, öğretmen tarafından kilitlendikten	Hayır	Sistemdeki "Salt Okunur" (Read-Only) veya kilit mekanizması atlatılmış (Bypass); yetkisiz manipülasyon yapılmış.

Durum / Senaryo	Integrity Sağlandı mı?	Teknik Analiz / Yorum
sonra (sistemde) değiştirilmesi.		
E-ticaret ödeme adımından (checkout) hemen önce sipariş fiyatının değiştirilmesi.	Hayır	İstemci-sunucu arasındaki veri bütünlüğü kontrol edilmemiş; manipüle edilmiş HTTP request parametreleri sunucu tarafından doğrulanmadan (Validation Missing) işleme alınmış.

Availability (Erişilebilirlik)

Availability (Erişilebilirlik: Kritik verilerin, servislerin ve sistem kaynaklarının yetkili kullanıcılar için "ihtiyaç duyulduğu her an" ulaşılabilir ve çalışır durumda olması), CIA üçgeninin son ancak operasyonel süreklilik (Business Continuity) açısından en hayati ayağıdır.

İşletmeler dijital servislere bağımlıdır. Bir sistemin "çok güvenli" olması ancak meşru kullanıcıların sisteme girememesi, o sistemin işlevsiz ve faydasız olduğu anlamına gelir. Saniyeler süren bir kesinti (downtime) bile devasa finansal zararlara ve itibar kaybına neden olabilir.

Saldırı Vektörü (Senaryo): Saldırganların hedef sunucuya aynı anda taşıyabileceğinden çok daha fazla ve sahte istek (request) göndererek sistem kaynaklarını (CPU, RAM, Bant Genişliği) tüketmesi. Buna **DoS / DDoS** (Denial of Service / Distributed Denial of Service) saldırısı denir. Bu saldırıda veri sızdırılmaz (Confidentiality) veya veri değiştirilmez (Integrity); ancak hedef web sitesi çöktüğü (offline) için meşru kullanıcılar hizmet alamaz ve işletme zarar eder.

Savunma Mekanizmaları: Bu tarz durumlarda Availability'yi garanti altına almak için sistemlerde donanımsal ve yazılımsal yedeklilik (**Redundancy** - örn: jeneratörler, UPS, failover sunucu kümeleri) ve trafik yükünü yönetip aşırı istekleri sınırlandıran **Rate Limiting / Load Balancing** (Yük dengeleme) mekanizmaları devreye sokulur.

DİKKAT: Fidyeye yazılımları (Ransomware), veriyi şifreleyerek erişilemez hale getirdiği için teknik olarak çok agresif bir Availability (ve aynı zamanda Confidentiality) ihlalidir.

Durum / Senaryo	Availability Sağlandı mı?	Teknik Analiz / Yorum
Yeni bir yazılımın/güncellemenin yüklenmesi sonucu kritik servislerin kesintiye uğraması.	Hayır	Hatalı yama yönetimi (Patch Management) veya test edilmemiş deployment, sistem kaynaklarını çökerterek erişilebilirliği yok etmiş.

Durum / Senaryo	Availability Sağlandı mı?	Teknik Analiz / Yorum
Şirketin web sitesinin mesai saatleri içerisinde çevrimdışı (offline) olması.	Hayır	Beklenmeyen bir çökme (Crash), ağ arızası veya DDoS sonucu hizmet kesintisi (Downtime).
Çalışma saatleri boyunca tüm sistemlerin çalışanların erişimine açık ve stabil olması.	Evet	Sistem uptime (çalışma süresi) metrikleri karşılanmış; operasyonel süreklilik sağlanmış.

CIA Üçlemesi

Güvenlik politikaları ve sistemlerinin geliştirilmesi için temel model. Her güvenlik önlemi, bu üç temel unsurdan en az birini ele almayı amaçlar.



C

Gizlilik

Hassas bilgilerin yetkisiz erişime karşı korunması



BEN

Bütünlük

Veri doğruluğunu sağlamak ve yetkisiz değişiklikleri önlemek



A

Müsaitlik

Gerektiğinde sistemlere ve verilere güvenilir erişimi garanti etmek.